Local gray-box security assessment

Portal + Common API + CIS API | Evidence: 5-6 November 2026 (Asia/Thimphu)

Assessment status: completed bounded campaign; coverage remains partial. Nuclei time limits and role-testing prerequisites prevent an exhaustive or clean-pass claim.

Targets: Portal http://host.docker.internal:3003, Common API :5003/common, CIS API :5016/cis_service. Local test environment, one supplied identity plus anonymous controls. Native scanner engine was invoked through a temporary operator CLI; these are operator artifacts, not new dashboard assessment rows.

Findings and triage

- The initial native web suite produced 69 raw findings: 68 Portal and one CIS. These are scanner observations, not 69 confirmed exploitable vulnerabilities.
- Portal: 46 publicly accessible JavaScript source maps and four filesystem path disclosures in the development server. Retest a production deployment; previous production-only source-map checks are separate evidence.
- HTTP transport is present on all supplied origins. TLS, Secure-cookie and HTTPS enforcement checks need an approved HTTPS endpoint to evaluate production transport.
- Portal HTML lacks CSP; image responses lack nosniff. Nikto also observed missing Permissions-Policy and other hardening headers. X-Frame-Options missing on an image does not demonstrate clickjacking of an interactive page.
- Ten Wapiti cookie-flag warnings concern five cookies returned by anonymous /api/auth/session as empty values with Max-Age=0. These delete cookies; they do not expose a live session token. See header-cookie-validation.json.
- Gitleaks' sole alert is notification-store.ts:3, the string `cis-approval-notifications-v1`, a localStorage key. False positive, not a secret.
- Trivy reported 104 lockfile vulnerability entries, including seven critical entries in the Portal's stale yarn.lock and one critical development dependency entry in Common's lockfile. Portal actually uses Bun; the stale yarn.lock must not be treated as its installed runtime.
- Matching Trivy alerts against all three installed production dependency graphs leaves 23 advisory entries: zero critical, one high, 20 medium and two low. The high is decode-uri-component 0.2.2 in Common through MinIO/query-string. Previous source tracing found only query-string.stringify calls in MinIO, not decoder calls; a dependency advisory match does not establish an exploitable endpoint. See runtime-trivy-matches.json. OSV's independent production-SBOM check reports 19 affected package/version entries; advisory databases and deduplication differ.
- Trivy Dockerfile checks: Common's image defaults to root (high); all three Dockerfiles omit HEALTHCHECK (low). These are build configuration findings, not proof of the current host process identity or deployed image state.
- Semgrep completed 91 rules over 2,080 files with zero findings. That is limited to the selected security-audit/TypeScript/React rule sets.

Execution and reliability

The broad authenticated native pipeline included httpx, Katana, browser discovery, Next.js assets, Nuclei, Wapiti, Dalfox, ZAP, API checks, and bounded exposed-files/VCS/Actuator/Kubernetes URL checks. Full API definitions were imported for Common and CIS; unresolved resource IDs were not invented. Independent Semgrep, Gitleaks, OSV, Trivy, Nikto, Nmap and Masscan also ran. Versions are recorded in tool-versions.json.

Nmap and Masscan were confined to the three supplied TCP ports; all were open. Nikto used GET-only configuration with a 210-second budget per origin, so its results are bounded, not exhaustive. Wapiti used safe GET testing; business writes, logout/reset/destructive paths and external callbacks were excluded.

The first broad Nuclei attempts loaded 8,589 signed templates with 242 incompatible/invalid templates and reached their eight-minute budgets. These are partial attempts, not clean passes. A narrower 703-template exposure campaign was used for recovery. Broader templates excluded destructive, out-of-band and command-execution classes. Native discovery also had explicit time/request budgets.

The initial run exposed two scanner bugs, fixed in commit 09b74cd: a successful Dalfox scan with no PoC file was marked as an artifact failure; an auth check canceled by a tool deadline could overwrite TIMEOUT as AUTH_FAILED. Full internal/scanner tests, go vet, and focused race tests passed. Recovery binary includes these changes. The running dashboard container has not been rebuilt with this commit.

ZAP initially failed because its service was not ready and then because network add-on 0.33.0 did not match the tested 0.28.0. A separate dedicated daemon with a fresh profile and silent mode restored the tested version; the adapter's version guard was preserved. Wapiti's initial concurrent first-start directory race was also observed; recovery reused the initialized directory. Initial failures remain in evidence.

Limits

No second live role account or disposable ownership fixture was supplied. Live cross-role/ownership vulnerability claims cannot be made. No controlled write, cache-reset or Server Action test campaigns were run without their fixture and cleanup requirements. TLS scanners are inapplicable to the supplied HTTP origins. Cloud scanners, host SSH audits and kube-bench require cloud/host/cluster inputs that were not supplied; subdomain expansion and arbitrary-port scanning would exceed the three local origins. No tool count can make those unavailable prerequisites into completed coverage.

See execution-matrix.json for each native attempt and its outcome, including recovery attempts and remaining failures. Raw source, scan output and reports are private local evidence under evidence/; treat them as sensitive. Source snapshots exclude .env files. This assessment is not a guarantee of absence of vulnerabilities.

Final recovery result

ZAP active executions completed on all three origins; coverage remains partial due to policy exclusions and headless limitations. Common returned zero alerts; CIS returned informational user-agent observations; Portal returned informational and low-severity header/redirect observations. Wapiti completed safe seed campaigns on all three apps. Dalfox completed the API seed campaigns and the final serialized Portal retry with zero PoCs. The earlier Portal session-verification failure is retained; its exact cause was not established. Nuclei remains time-limited; all-template completion is not claimed.

Final artifact checksums have zero mismatches. One preserved parse error belongs to the failed Common ZAP attempt with no artifact; its completed retry parsed successfully. See TOOL-MATRIX.md and execution-matrix.json. Fixes are committed; the dashboard runtime needs rebuilding to include them. The temporary dedicated ZAP daemon and API key were removed.

Tool coverage and exclusions

Results below describe the selected local scope. A completed execution can still have policy exclusions or limited inventory.

Tool / adapter	Target	Result / limit
httpx	all three origins	Completed reachability and technology observations
Katana + headless discovery	all three	Broad discovery completed/limited; some shorter retries exhausted discovery budgets
Next.js assets	Portal and API control origins	Portal maps/paths found; APIs not Next.js
Nuclei	all three	Broad 8-minute and exposure-only 5-minute attempts partial; no clean-pass claim
ZAP	all three	Active execution completed after retries; coverage marked partial because unsafe/out-of-scope requests and headless DOM checks were excluded
Wapiti	all three	Safe GET seed campaigns completed; HTTP/dev information/header observations
Dalfox	APIs	Completed selected parameterized seed campaigns, zero PoCs; headless DOM verification excluded
Dalfox	Portal	Final serialized retry completed with zero PoCs; headless DOM verification excluded
API checks	Common, CIS, Portal API seeds	Declared-auth/CORS checks; not exhaustive role/ownership testing
Exposed files, VCS metadata, Actuator, Kubernetes HTTP checks	all three	Bounded read-only URL checks completed, zero findings
Semgrep	all three source snapshots	Completed 91 rules, 2,080 files, zero findings
Gitleaks	source snapshots	One localStorage-key false positive; no verified credential leak
OSV	locks + installed production SBOMs	Completed; runtime SBOM attribution recorded separately
Trivy	source filesystem/locks/Dockerfiles	Completed after DB download retry; advisory + Dockerfile findings
Native Next.js SAST/deps	all three snapshots	Completed; Portal stale Yarn lock generates mismatched runtime alerts
Nikto	all three origins	GET-only, 210-second bounded campaign per origin; header observations
Nmap	exactly TCP 3003,5003,5016	Completed, three open services
Masscan	exactly TCP 3003,5003,5016 on resolved local host	Completed, three open ports; rate 30

Tool / adapter	Target	Result / limit
testssl.sh / SSLyze	supplied HTTP origins	Not applicable: no approved HTTPS origin
subfinder / arbitrary-port host scanning	local scope	No approved DNS/extra-port scope
kube-bench, Prowler, Scout	host/cloud/cluster	No cluster, cloud account or host audit inputs

No external proxy acceptance target was used. No external callbacks, credential spraying, destructive business writes, or uncontrolled cache/action mutations were authorized by these runs. A second live role account and disposable ownership records are still needed for cross-role ownership tests.

Evidence reference

Local evidence folder: build/full-tools-20261105T144733Z. The execution matrix, runtime advisory attribution, tool versions and raw outputs remain available there. Credentials and session tokens are excluded from this PDF. No new scan was performed to generate this document.